

## **Manual 36 — Implementação Controlada da LGPD do Brasil**

**\*\*Idioma:\*\*** Português do Brasil (pt-BR)

**\*\*Linha de base controlada:\*\*** Lei nº 13.709/2018 (LGPD) vigente e regulamentos vinculantes da ANPD verificados em 31-08-2026.

**\*\*Limite:\*\*** Estatuto, regulamento vinculante da ANPD, orientação/enforcement, lei setorial, contrato e prática organizacional permanecem separados. Esta é uma tradução de projeto não oficial e não constitui aconselhamento jurídico nem aprovação regulatória.

### **Chapter 01 — Objetivo, escopo e hierarquia controlada de fontes**

Use a LGPD consolidada e os instrumentos vinculantes da ANPD como fontes controlantes para tratamento coberto. Classifique orientações, enforcement, regras setoriais, contratos e procedimentos internos por status e data.

Mantenha registro datado de fontes, responsável pela aplicabilidade, change watch e evidência de reavaliação antes do release.

### **Chapter 02 — Aplicabilidade, alcance territorial e análise jurisdicional**

Documente por que uma atividade está dentro ou fora do alcance territorial da LGPD, considerando tratamento no Brasil, oferta a pessoas no Brasil e coleta no Brasil, além de exclusões e overlays setoriais.

Preserve avaliação de aplicabilidade, fatos, reviewer responsável, exceções e gatilhos de reavaliação.

### **Chapter 03 — Dados pessoais, dados sensíveis e conceitos de tratamento**

Mantenha definições controladas para dados pessoais, sensíveis, anonimizados, tratamento, banco de dados, titular, controlador, operador e conceitos relacionados. Resolva conflitos terminológicos antes que cheguem a notí­cias, contratos, sistemas ou incidentes.

Preserve glossário, regras de classificação, exemplos, decisões e histórico terminológico.

### **Chapter 04 — Controlador, operador, encarregado e papéis de accountability**

Identifique responsabilidades reais de controlador e operador e mantenha a governança do encarregado/DPO exigida pela LGPD e ANPD. A atribuição deve seguir autoridade decisória e fatos, não apenas rótulos contratuais.

Preserve matrizes de papéis, nomeações, canais de contato, instruções, escalonamento e registros de accountability.

## **Chapter 05 — Modelo de governança, políticas e responsabilidades de privacidade**

Estabeleça governança aprovada com accountability executiva, ownership de políticas, papéis operacionais, escalonamento de risco, assurance e management review periódico. Integre privacy com security, legal, produto, procurement, data, RH e negócio.

Preserve policies, charters, RACI, atas, issues e corrective actions.

## **Chapter 06 — Inventário e registros de tratamento**

Mantenha inventário atual de atividades, sistemas, datasets, finalidades, categorias, dados sensíveis, titulares, bases legais, destinatários, operadores, transferências, retenção, security controls e owners.

Atualize o inventário quando mudarem produtos, vendors, finalidades, fluxos, tecnologias ou condições legais.

## **Chapter 07 — Bases legais e análise de finalidade/necessidade**

Registre a base legal LGPD aplicável a cada finalidade material e teste separadamente legitimidade, adequação e necessidade. Não substitua outra base por consentimento nem presuma que uma base cobre usos secundários não relacionados.

Preserve lawful-basis register, finalidades, necessity assessments, approvals, exceções e datas de revisão.

## **Chapter 08 — Governança do consentimento e retirada**

Quando consentimento for a base, projete coleta demonstrável e específica e permita retirada por processos controlados. Evite dark patterns, finalidades agrupadas ou continuidade de tratamento após retirada válida sem outra base documentada.

Preserve texto/versão, timestamp, origem, retirada, propagação downstream, exceções e testes.

## **Chapter 09 — Legitimate-interest assessment e balancing**

Quando legítimo interesse for utilizado, documente finalidade, necessidade, expectativas, impactos, safeguards, transparência e conclusão de balanceamento. Escale usos com intrusão relevante, dados sensíveis, crianças, monitoring, profiling ou uso secundário inesperado.

Preserve assessment, fatos, controles mitigadores, aprovação e gatilhos de mudança.

## **Chapter 10 — Governança de dados de crianças e adolescentes**

Trate dados de crianças e adolescentes como área de governança reforçada com análise específica de aplicabilidade e melhor interesse. Preserve idade, processos parentais quando aplicáveis, transparência, minimização, segurança e product safeguards.

Preserve avaliação, notices, análise de base/consentimento, design review, testes, reclamações e remediação.

## **Chapter 11 — Operações de direitos dos titulares**

Opere intake, validação de identidade, routing, busca, decisão, resposta, correção, portability/change-watch, eliminação, oposição e escalonamento documentados. Não prometa direitos ou prazos além da fonte vigente salvo quando identificados como policy commitment.

Preserve request logs, identity evidence, buscas, decisões, respostas, exceções e métricas.

## **Chapter 12 — Notices de transparência e deveres de informação**

Mantenha notices alinhados ao tratamento real, finalidades, sharing, direitos, identidade do controlador, contato do encarregado, transferências e automação material. Reconcilie notices com inventários, contratos, produtos e mudanças.

Preserve versões, approvals, datas, change records, readability review e reconciliação com sistemas.

## **Chapter 13 — Qualidade, minimização, retenção, eliminação e anonimização**

Colete e retenha apenas dados necessários, mantenha controles razoáveis de qualidade e aplique retention/deletion defensável. Trate claims de anonimização como conclusões técnicas/jurídicas que exigem evidência sobre risco de reidentificação.

Preserve schedules, deletion evidence, quality controls, anonymization assessments, exceções e backup/disposal handling.

## **Chapter 14 — Privacy by design/default e change management**

Integre privacidade aos gates de produto, sistema, procurement, analytics, IA e processos. Exija privacy review diante de mudanças materiais em finalidade, categorias, destinatários, transfers, profiling, monitoring ou tecnologia de alto risco.

Preserve checklists, architecture decisions, DPIA/risk artifacts, approvals, test results e change tickets.

## **Chapter 15 — Salvaguardas de segurança e controles administrativos/técnicos**

Implemente medidas administrativas, técnicas e físicas razoáveis conforme sensibilidade, volume, ameaças, contexto e impacto. Integre IAM, configuração segura, logging, vulnerability management, encryption, resilience, secure development, monitoring e incident response.

Preserve mappings, testing evidence, vulnerabilities, exceções, remediação e risk acceptance.

## **Chapter 16 — Incidentes e comunicação à ANPD/titulares**

Use processo documentado alinhado ao regulamento vigente de comunicação de incidentes da ANPD. Determine se há dados pessoais, avalie dano/risco e critérios de notificação, preserve timing e coordene comunicações quando legalmente exigidas.

Preserve fatos, assessment, autoridade decisória, notifications, timestamps, remediação e lessons learned.

## **Chapter 17 — Risk assessment, privacy impact e tratamento de alto risco**

Aplique avaliações de risco e impacto a tratamento material ou high-risk, incluindo escala, dados sensíveis, grupos vulneráveis, monitoring, profiling, novas tecnologias e decisões automatizadas significativas. Use requisitos/solicitações ANPD vigentes sobre impact reports quando aplicáveis.

Preserve metodologia, assessment, residual risk, safeguards, approvals e review cycle.

## **Chapter 18 — Transferências internacionais e mecanismos**

Aplique a LGPD e o regulamento vigente da ANPD às transferências cobertas. Determine alcance, base legal, mecanismo válido, transparência, onward transfer e safeguards. Preserve a retificação de 2025 e decisões de adequação vigentes no source control.

Preserve transfer inventory, mecanismo, adequacy decision quando usado, cláusulas ou mecanismo aprovado, due diligence, contrato e reassessment.

## **Chapter 19 — Lifecycle de vendors, operadores e suboperadores**

Avalie risco de operadores, subprocessors, cloud/SaaS e outros recipients antes e durante a relação. Defina instruções, finalidade, security, rights assistance, incidents, transfers, retention, audit rights e exit.

Preserve due diligence, contratos, operator register, subprocessor changes, monitoring, issues e termination evidence.

## **Chapter 20 — Contratos, instruções, confidencialidade e responsabilidade compartilhada**

Converta requisitos em instruções e termos claros sem permitir que rótulos contratuais substituam papéis legais reais. Identifique responsabilidades compartilhadas, security duties, rights support, transfers, incident cooperation e evidence retention.

Preserve executed terms, responsibility matrix, instruction history, confidentiality controls e amendments.

## **Chapter 21 — Cloud, SaaS, managed service e processamento transfronteiriço**

Mapeie localizações de dados, admins, subprocessors, telemetry, backups, support access, encryption, deletion, resilience e fluxos internacionais. Resolva transfer mechanism e operator responsibilities antes de produção.

Preserve cloud inventory, architecture/data-flow maps, shared responsibility, configurations, contracts, transfer assessments e exit plans.

## **Chapter 22 — Marketing, profiling, decisões automatizadas e analytics**

Governe marketing, profiling, analytics, personalização e automated decisions com base legal, transparência, minimização, qualidade, rights support, review mechanisms e anti-discrimination controls quando aplicáveis. Não exagere direitos legais sem análise vigente.

Preserve use-case assessments, rules/models, notices, rights handling, review evidence, métricas e complaints/remediation.

## **Chapter 23 — Privacidade laboral, acesso, monitoring e training**

Aplique LGPD a dados de empregados, candidatos e contractors separando requisitos trabalhistas. Limite access e monitoring a finalidades documentadas com proporcionalidade, transparência, retenção e escalation.

Preserve workforce notices, access reviews, monitoring assessments, retention, training, investigations e exceptions.

## **Chapter 24 — Registros físicos e dados não digitais**

Inclua arquivos em papel, visitantes, mídias físicas, correio e outros tratamentos não digitais quando a LGPD se aplicar. Controle storage, access, transport, copying, retention, destruction e incident handling.

Preserve inventories, access controls, disposal certificates, facility reviews e incident evidence.

## **Chapter 25 — Agentes de pequeno porte e tratamento diferenciado**

Determine se as regras ANPD para agentes de pequeno porte se aplicam e quais simplificações concretas existem. Não trate esse status como isenção geral de princípios LGPD, segurança, direitos ou obrigações não dispensadas.

Preserve eligibility analysis, simplifications, retained obligations, review triggers e evidence.

## **Chapter 26 — Regulamentos ANPD, orientação, inspeções, sanções e readiness**

Mantenha obligation register distinguindo regulations vinculantes de guidance, FAQs, consultas, enforcement facts e agenda futura. Prepare evidence para fiscalização e sanções sem converter casos de terceiros em regras universais.

Preserve regulatory register, inspection protocol, legal holds, response packages, sanction analysis, findings e corrective actions.

## **Chapter 27 — Mapping de overlays setoriais e leis adjacentes**

Mapeie requisitos consumer, employment, financial, health, telecom, digital platform, child protection, cybersecurity, records e outros do Brasil separados da LGPD. Identifique controles adicionais sem atribuí-los à fonte errada.

Preserve overlay matrix, owners, citations, applicability decisions, conflicts e change watch.

## **Chapter 28 — Arquitetura de evidência, audit trail e accountability**

Projete rastreabilidade entre requirement, owner, procedure, system/control, test, exception, remediation e decision. Proteja integrity, access, retention, confidentiality e version history.

Preserve evidence indexes, control maps, workpapers, approvals, logs, findings, remediation e provenance.

## **Chapter 29 — Exceções, remediação, risk acceptance e reporting**

Exija exceções documentadas com scope, rationale, compensating controls, owner, approval, duration, residual risk e expiration. Escale issues vencidos ou de alto impacto a management e liderança legal/privacy.

Preserve exception registers, corrective actions, risk acceptances, dashboards, escalation e closure evidence.

## **Chapter 30 — Regulatory change watch e gatilhos de reavaliação ANPD**

Monitore LGPD consolidada, regulamentos ANPD, amendments/rectifications, adequacy decisions, agenda regulatória, priority topics, guidance material e mudanças organizacionais que afetem aplicabilidade.

Preserve snapshots datados, change assessments, owners, implementation plans, effective dates e candidate-supersession decisions.

## **Chapter 31 — Exact-hash review, localização, provenance e release evidence**

Congele a fonte controlada antes de candidate generation. Vincule artefatos EN/es-419/pt-BR DOCX/PDF a SHA-256 exatos e preserve accessibility, render, source, localization, workflow-security e release-QA evidence.

Toda mudança material pós-freeze exige supersession, regeneração, re-hashing e re-review dos gates afetados.

## Chapter 32 — Roadmap, maturidade e reverificação de release

Implemente em fases: applicability/inventory, governance/lawful bases, rights/notices, security/incidents, transfers/vendors, high-risk processing e assurance/evidence. Meça maturidade por outcomes respaldados por evidência.

Antes da publicação, reverifique LGPD consolidada, regulations/rectifications ANPD, incident rules, DPO, transfers/adequacy, small-agent treatment, sanctions/enforcement e overlays materiais. A publicação permanece sequencial após o Manual 35 e exige todos os gates determinísticos em verde.